ITPE 2

MANAGING CYBERSECURITY: GOVERNANCE, ROLES, AND STRUCTURE



Presented By **Group 2**

TABLE OF CONTENTS

III. CYBERSECURITY MANAGEMENT CONCEPTS

- 3.1. SECURITY GOVERNANCE
- 3.2. MANAGEMENT MODELS

IV. ENTERPRISE ROLES AND STRUCTURE

- 4.1. INFORMATION SECURITY ROLES AND POSITIONS
- 4.2. ALTERNATIVE ENTERPRISE STRUCTURES AND INTERFACES

CYBERSECURITY MANAGEMENT CONCEPTS



INTRODUCTION / OVERVIEW

- This topic covers the foundational concepts that support cybersecurity management — not yet the full practice itself, but the ideas and principles it is built on
- These concepts include how organizations set direction (governance) and how that direction is carried out (management models, roles, and functions)
- Understanding these concepts first is essential before an organization can practice cybersecurity management effectively



WHY IT MATTERS ?



Concepts serve as the foundation — without understanding them, actual management efforts can become inconsistent or misdirected



They provide the vocabulary and framework needed to make informed security decisions



They help distinguish between different responsibilities: who sets policy versus who carries it out



A solid grasp of these concepts allows for more effective real-world application later on

SCOPE OF THIS TOPIC

- This topic is composed of two major areas:

    i. **Security Governance** — the framework of policies, leadership direction, and accountability that guides security decisions at the organizational level
    ii. **Management Models, Roles, and Functions** — the practical structures, approaches, and responsibilities used to implement and sustain those decisions

- Together, these establish both the **"why/direction"** and the **"how/execution"** of managing cybersecurity



MOVING FORWARD

- These two concepts are not separate ideas — governance concepts explain direction, while management concepts explain execution
- Understanding one without the other gives an incomplete picture of how cybersecurity management works
- As we move into the discussion, take note of how each concept connects to real organizational decisions
- This lays the groundwork for later applying these concepts to actual cybersecurity management practice



SECURITY GOVERNANCE



WHO IS RESPONSIBLE FOR CYBERSECURITY IN AN ORGANIZATION?

SECURITY GOVERNANCE IS ABOUT ESTABLISHING DIRECTION, AUTHORITY, RESPONSIBILITY, ACCOUNTABILITY, AND OVERSIGHT FOR PROTECTING INFORMATION AND TECHNOLOGY ASSETS.



Governance

The organization decides that customer data must be protected according to its sensitivity and applicable regulations.



Management

The security team implements encryption, access controls, monitoring, and data-loss prevention.

SO WHAT EXACLTY IS BEING

SO WHAT EXACLTY IS BEING GOVERNED?

- INFORMATION
  Any information such as personal information, intellectual property, credentials and etc.
- TECHNOLOGY
  Cloud infrastructure, computers, networks, databases and etc.
- PEOPLE
  Employees, Contractors, Customers, and etc.
- PROCESSES
  Authentication, Incident Response, Access Approval, Backups, and Software Development.

C CONFIDENTIALITY

Ensure information is accessible only to authorized people.

I INTEGRITY

Keep information accurate, complete and unaltered.

A AVAILABILITY

Ensure information and systems are available when needed.



SECURITY GOVERNANCE IS FUNDAMENTALLY ABOUT RISK

MANAGEMENT MODELS, ROLES, AND FUNCTIONS



UNDERSTANDING

MANAGEMENT MODELS, ROLES, AND FUNCTIONS

Cybersecurity management is the process of directing and coordinating an organization's security activities to protect information, systems, and business operations.

Main Areas:

- **Management Models** - frameworks used to organize and manage cybersecurity
- **Management Roles** - people responsible for security decisions and activities
- **Management Functions** - activities used to plan, implement, monitor, and improve security



Their main purpose is to ensure that cybersecurity supports organizational goals while managing security risks effectively.

CYBERSECURITY MANAGEMENT MODELS

WHAT ARE MANAGEMENT MODELS?

Management models provide a structured approach for organizing cybersecurity activities, responsibilities, and decision-making.

COMMON MODELS / FRAMEWORKS

NIST Cybersecurity Framework (CSF 2.0)

- Designed to help organizations manage cybersecurity risk
- Six functions: Govern, Identify, Protect, Detect, Respond, Recover

ISO/IEC 27001

- Provides requirements for an Information Security Management System (ISMS)
- Focuses on identifying, managing, and continually improving information-security risks

COBIT 2019

- Focuses on governance and management of enterprise information and technology

Key point:
These models can be used separately or together depending on an organization's needs.

NIST CSF 2.0

NIST CYBERSECURITY FRAMEWORK AS A MANAGEMENT MODEL

NIST CSF 2.0 organizes cybersecurity outcomes into six functions:

1. **Govern:** Important to management, it establishes cybersecurity strategy, policies, roles, and risk expectations
2. **Identify:** Understand assets, risks, threats, and organizational context
3. **Protect:** Implement safeguards to reduce cybersecurity risks
4. **Detect:** Identify and analyze possible cybersecurity events
5. **Respond:** Take action when a cybersecurity incident occurs
6. **Recover:** Restore affected systems, assets, and operations

Why it is useful:

- Provides a common cybersecurity language
- Helps prioritize cybersecurity risks
- Supports communication between management and technical teams
- Can be adapted to organizations of different sizes and industries

MANAGEMENT ROLES

WHO MANAGES CYBERSECURITY?

Cybersecurity is a shared organizational responsibility.

Executive Management / Board

- Establishes direction and priorities
- Provides resources
- Oversees major cybersecurity risks

CISO (Chief Information Security Officer)

- Leads the information-security program
- Develops security strategy and policies
- Manages security risks
- Reports major risks and incidents to leadership

Security and IT Professionals

- Implement security controls
- Monitor systems
- Investigate threats
- Respond to incidents

System / Data Owners

- Determine security requirements
- Control access decisions
- Manage risks associated with their systems or information

FIVE CORE MANAGEMENT FUNCTIONS

1. **Planning**
   - Identify security objectives and risks
   - Establish policies and priorities
   - Determine resources and security strategies
2. **Organizing**
   - Assign responsibilities
   - Establish security teams and reporting structures
   - Allocate resources
3. **Staffing**
   - Recruit qualified personnel
   - Identify required cybersecurity skills
   - Provide training and development
4. **Leading / Directing**
   - Communicate security priorities
   - Coordinate teams
   - Make security decisions
   - Guide incident response
5. **Controlling**
   - Monitor security performance
   - Evaluate risks and controls
   - Check compliance
   - Correct weaknesses
   - Continuously improvesecurity

Simple process:

Plan → Organize → Staff → Lead → Control → Improve

HOW MODELS, ROLES, AND FUNCTIONS WORK TOGETHER

PUTTING CYBERSECURITY MANAGEMENT INTO PRACTICE

Cybersecurity management works when the framework, people, and activities support one another.



Management Model

Provides the structure

↓

Management Roles

Assign responsibility and accountability

↓

Management Functions

Plan, organize, implement, monitor, and improve security

↓

Security Outcomes

Reduced risk + Better protection + Business continuity

HOW MODELS, ROLES, AND FUNCTIONS WORK TOGETHER

PUTTING CYBERSECURITY MANAGEMENT INTO PRACTICE

Example:

A company identifies a high risk of unauthorized account access.



Management model:

NIST CSF → Identify the risk and Protect the organization

Management role:

CISO → recommends stronger authentication

Management function:

Planning → selects an appropriate security measure

Implementation:

IT team → deploys multi-factor authentication

Control:

Management → monitors whether unauthorized access decreases

ENTERPRISE ROLES AND STRUCTURES



INTRODUCTION / OVERVIEW

- This topic covers the concepts behind how enterprises assign and organize responsibility for information security — not yet the full practice, but the underlying ideas that shape it
- These concepts include the specific roles and positions dedicated to security, as well as the structural models organizations use to arrange those roles
- Understanding these concepts first makes it easier to see why certain organizational designs are used in



WHY IT MATTERS ?



Concepts around roles and structures form the foundation for accountability — without them, responsibilities can overlap or go unassigned



They provide a shared understanding of who is responsible for what within a security function



They help explain why organizations choose different structural approaches depending on their size, industry, or needs



A solid grasp of these concepts supports better organizational design and decision-making later on

SCOPE OF THIS TOPIC

- This topic is composed of two major concepts:

    i. **Information Security Roles and Positions** — the concept of specific titles, duties, and responsibilities within a security function (e.g., CISO, security analysts, auditors)
    ii. **Alternative Enterprise Structures and Interfaces** — the concept of how organizations can be arranged (centralized, decentralized, hybrid) to support those roles

- Together, these represent the "who" and "how it's organized" concepts behind enterprise security



MOVING FORWARD

- These two concepts are closely connected — role concepts explain responsibility, while structure concepts explain how those responsibilities connect across the organization
- Understanding one without the other gives an incomplete picture of how enterprise security is organized
- As we move into the discussion, pay attention to how different roles function within varying structural setups
- This lays the groundwork for later applying these concepts to real organizational design



INFORMATION SECURITY ROLES AND POSITIONS



INTRODUCTION

Information Security Roles and Positions

- Information security roles are positions responsible for protecting an organization's data, systems, networks, and information.
- Each role has different responsibilities.
- They work together to maintain confidentiality, integrity, and availability of information.



CHIEF INFORMATION SECURITY OFFICER (CISO)

The CISO is the highest-level person responsible for cybersecurity in an organization.

Responsibilities:

- Develop cybersecurity strategies
- Create security policies
- Manage cybersecurity risks
- Lead the security team
- Report security issues to top management



SECURITY MANAGER

The Security Manager handles the day-to-day management of information security.

Responsibilities:

- Implement security policies
- Manage security personnel
- Monitor security operations
- Conduct security assessments
- Coordinate security activities



SECURITY ANALYST

A Security Analyst monitors systems and networks to detect and investigate security threats.

Responsibilities:

- Monitor security alerts
- Analyze security logs
- Investigate suspicious activities
- Identify vulnerabilities



SECURITY ENGINEER

A Security Engineer designs and maintains the technical security defenses of an organization.

Responsibilities:

- Configure firewalls
- Maintain security systems
- Protect networks and servers
- Implement access controls
- Install and manage security tools



SECURITY ADMINISTRATOR & INCIDENT RESPONSE TEAM

Security Administrator

- Manages user accounts and permissions
- Controls access to systems
- Maintains security configurations
- Applies security updates

Incident Response Team

- Responds to cybersecurity incidents
- Investigates and contains attacks
- Removes threats
- Helps recover affected systems



SUMMARY

Information Security Roles and Their Functions

- **CISO** – Leads and oversees the organization's cybersecurity.
- **Security Manager** – Manages daily security operations and personnel.
- **Security Analyst** – Detects, analyzes, and investigates security threats.
- **Security Engineer** – Builds and maintains technical security defenses.
- **Security Administrator** – Manages user access, accounts, and security configurations.
- **Incident Response Team** – Responds to and manages cybersecurity incidents.

ALTERNATIVE ENTERPRISE STRUCTURES AND INTERFACES



ENTERPRISE STRUCTURES AND THEIR IMPORTANCE

An enterprise structure defines how an organization organizes its departments, people, responsibilities, decision-making authority, and resources. In cybersecurity, the structure determines who is responsible for protecting information, managing risks, responding to incidents, and enforcing security policies.

- Establishes cybersecurity roles and responsibilities
- Defines reporting and decision-making relationships
- Determines how security resources are allocated
- Influences communication between departments
- Supports accountability for cybersecurity risks
- Helps align security with business objectives



MAJOR ENTERPRISE STRUCTURES

Organizations can use different structures depending on their size, business model, and cybersecurity requirements. The most common approaches are centralized, decentralized, and hybrid structures, with other structures such as functional, divisional, and matrix models used for more complex organizations.

Centralized

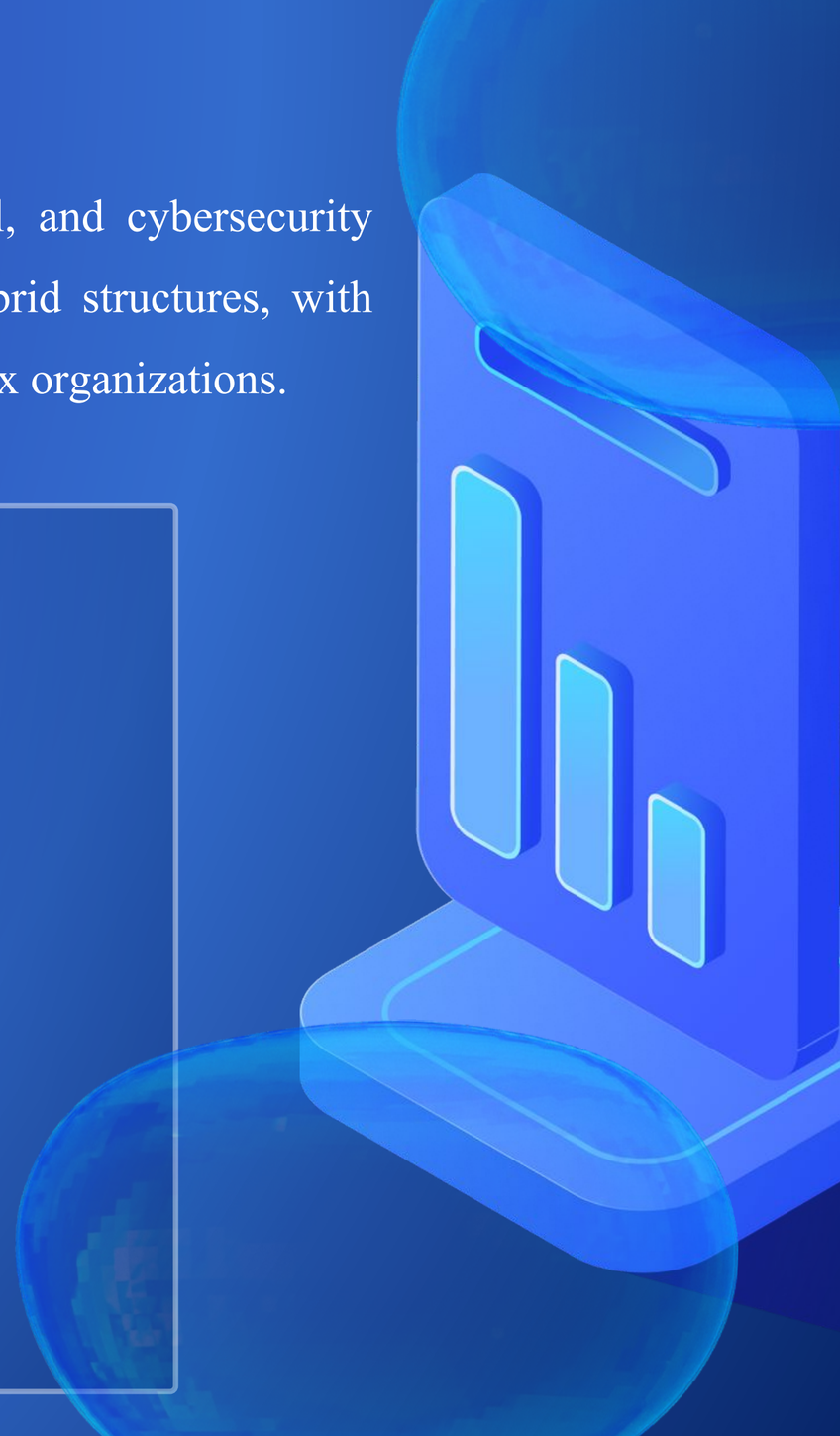
- Security decisions are controlled by a central cybersecurity or IT team.
- Provides consistency, standardization, and centralized monitoring.
- May provide less flexibility for individual departments.

Decentralized

- Business units manage many of their own cybersecurity activities.
- Provides flexibility and faster local decision-making.
- Can result in inconsistent security practices.

Hybrid

- Combines centralized security governance with decentralized implementation.
- Provides enterprise-wide standards while allowing business-unit flexibility.
- Commonly suitable for large and complex organizations.

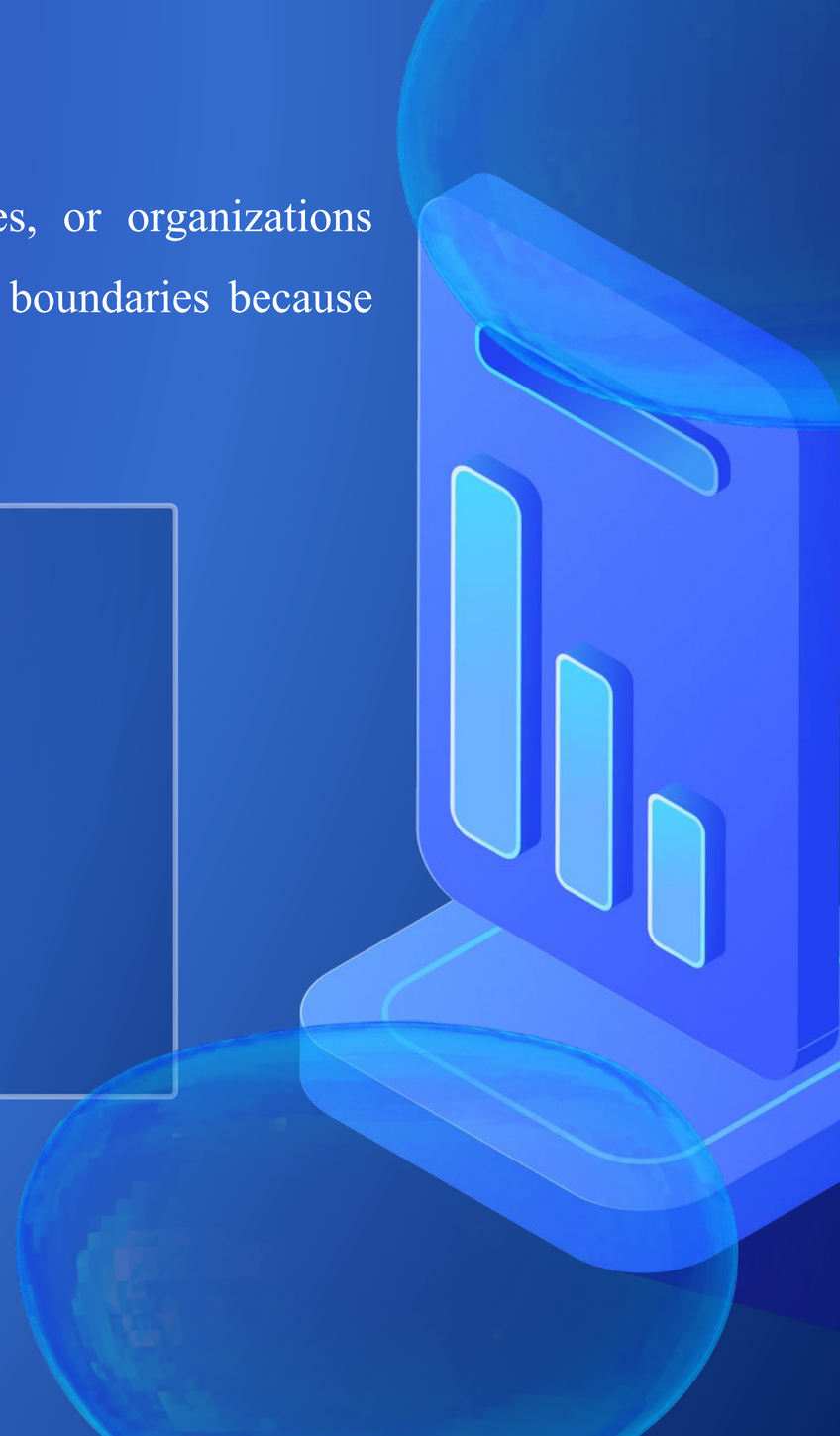


ENTERPRISE INTERFACES

An enterprise interface is a point where different departments, systems, processes, or organizations communicate or exchange information. These interfaces are important cybersecurity boundaries because sensitive data and system access often pass through them.

Important interfaces include:

- Cybersecurity ↔ IT: Infrastructure protection and security controls
- Cybersecurity ↔ Management: Security strategy, risk, and funding
- Cybersecurity ↔ HR: Employee access, onboarding, termination, and training
- Cybersecurity ↔ Legal: Privacy, contracts, and regulatory compliance
- Cybersecurity ↔ Finance: Financial fraud and risk management
- Cybersecurity ↔ Vendors: Third-party security and access
- System ↔ System: APIs, networks, databases, and cloud services



CYBERSECURITY RISKS AT ENTERPRISE INTERFACES

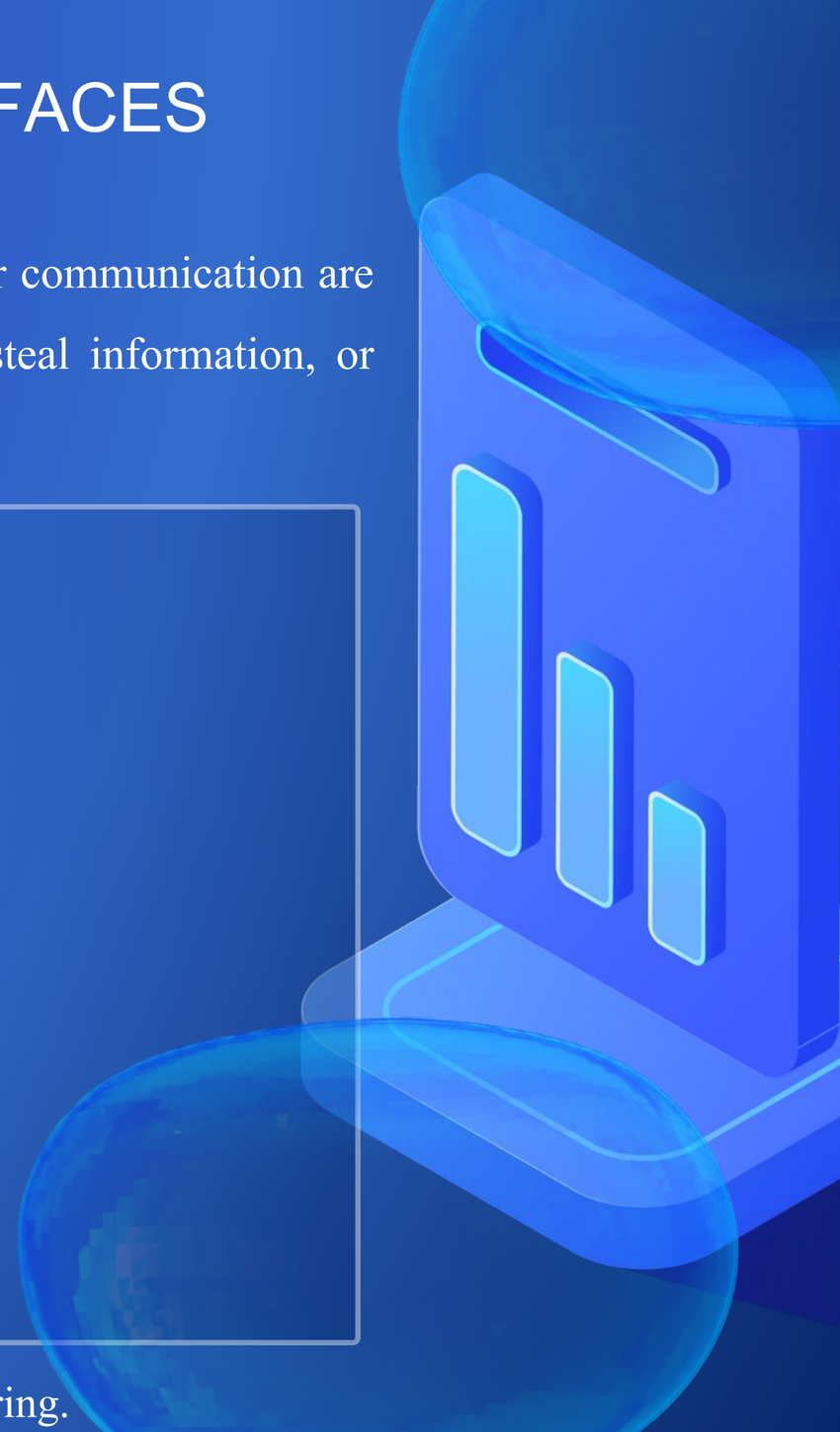
Enterprise interfaces can become security weaknesses when responsibilities, access, or communication are poorly managed. Attackers may exploit these gaps to obtain unauthorized access, steal information, or move between interconnected systems.

Common risks:

- Unclear security responsibilities
- Excessive user privileges
- Poor communication between departments
- Inconsistent security policies
- Unsecured system connections
- Weak third-party security
- Data leakage
- Delayed incident reporting
- Unauthorized access between systems

Key principle:

Every interface should have clearly defined ownership, security requirements, and monitoring.

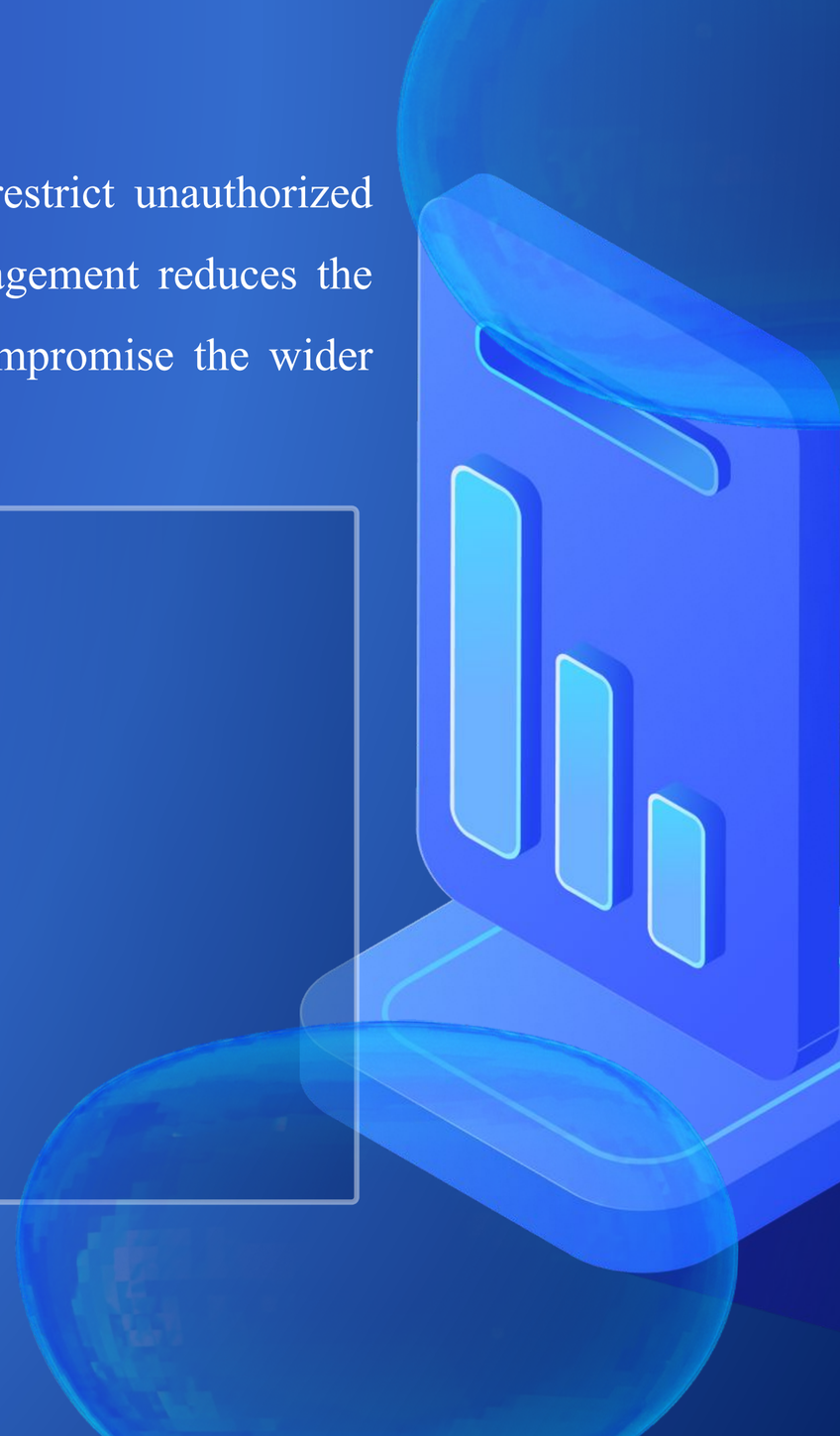


MANAGING ENTERPRISE INTERFACES

Organizations must protect enterprise interfaces by applying security controls that restrict unauthorized access and provide visibility into system and user activity. Effective interface management reduces the possibility that weaknesses in one department, system, or external provider will compromise the wider organization.

Key security practices:

- Apply least privilege access
- Use strong authentication and authorization
- Encrypt sensitive information
- Monitor network and system connections
- Conduct regular risk assessments
- Establish clear security responsibilities
- Control third-party access
- Maintain incident reporting and escalation procedures
- Regularly review user and system permissions



ZERO TRUST AND SHARED RESPONSIBILITY

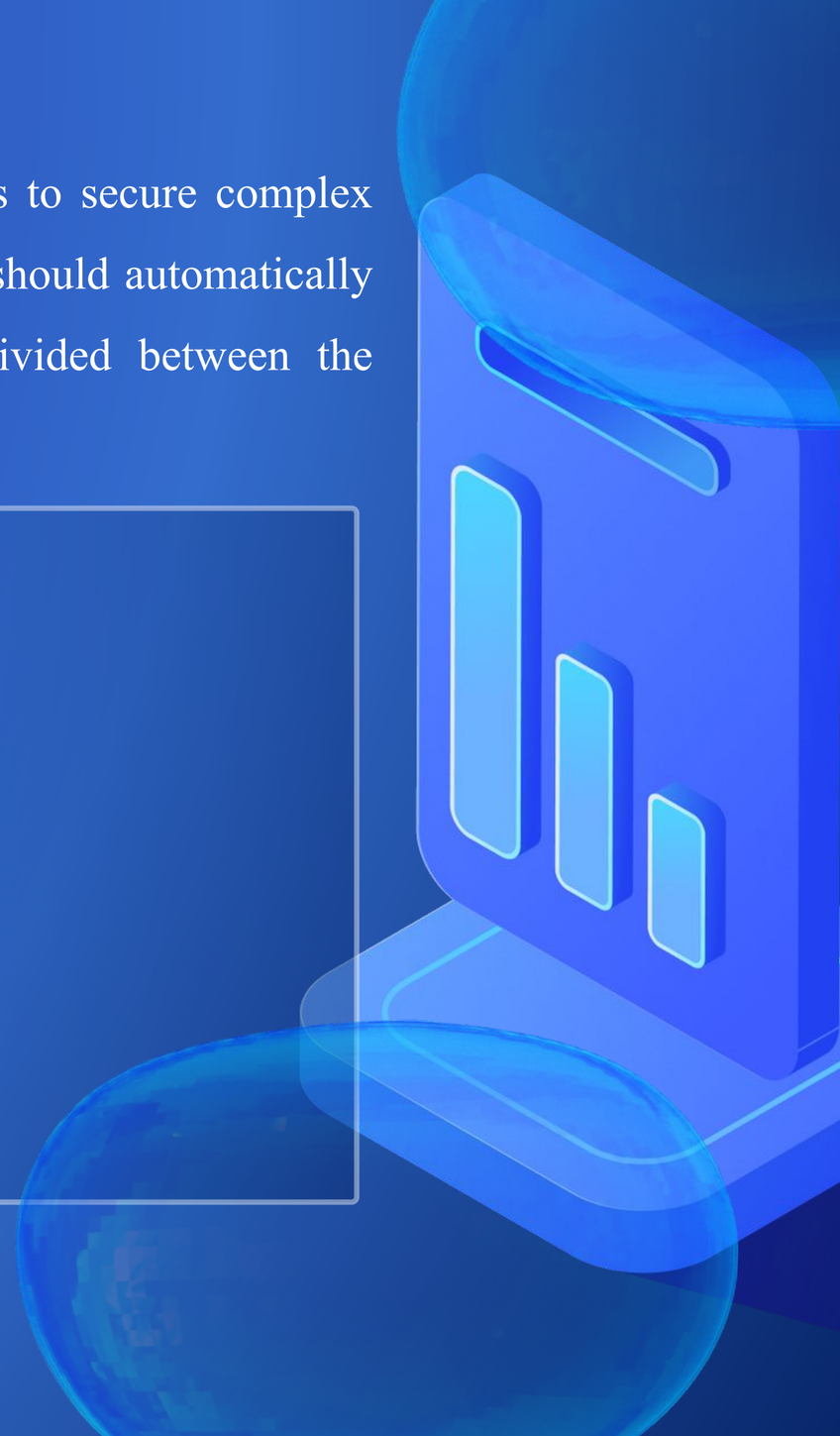
Modern enterprises increasingly use Zero Trust and shared responsibility approaches to secure complex organizational environments. Zero Trust assumes that no user, device, or connection should automatically be trusted, while shared responsibility ensures that security duties are clearly divided between the organization and its service providers.

Zero Trust principles:

- Verify users and devices explicitly
- Apply least-privilege access
- Assume potential compromise
- Continuously monitor activity
- Segment sensitive systems and resources

Shared responsibility:

- Organization → Data, users, identities, configurations, and access
- Service provider → Underlying infrastructure and agreed services
- Security team → Governance, monitoring, risk management, and response



KEY TAKEAWAYS AND CONCLUSION

An effective cybersecurity structure must clearly define who is responsible for security while allowing departments and systems to work together safely. The organization should select a structure that balances centralized control, operational flexibility, accountability, and business requirements.

Key takeaways:

- Centralized: Strong control and consistency
- Decentralized: Greater flexibility and local control
- Hybrid: Balance between enterprise governance and business-unit flexibility
- Interfaces: Critical points where people, systems, and organizations interact
- Interface risks: Can create unauthorized access, data leakage, and security gaps
- Security controls: Least privilege, authentication, encryption, monitoring, and clear accountability
- Zero Trust: Never automatically trust users, devices, or connections

Conclusion:

Effective enterprise structures and secure interfaces enable organizations to manage cybersecurity risks while maintaining efficient business operations.

THANK YOU

Questions? Feel free to reach out

www.reallygreatsite.com

hello@reallygreatsite.com

